Загуглить противника

Программа настоящая.
А поддержка?

Что именно докажет внешний поиск?

Компания / Имя спикера

УЧЕБНАЯ СИТУАЦИЯ

1. Письмо о подписке
2. Звонок по номеру из счёта
3. Запуск удалённой поддержки

Внешний адрес — подсказка

Адрес — наблюдение.
IoC — признак с основанием.

СЕТЬ

IP · домен · URL

ФАЙЛ

Байты · имя · SHA-256

КОНТЕКСТ

Письмо · телефон · сеанс

Наблюдение + роль + период + основание → IoC

Совпадение — повод проверить событие.

От репутации до hunting

01
Репутация
Что сообщали?

›

02
Обогащение
Что известно?

›

03
Анализ TI
Что это объясняет?

›

04
Расследование
Что произошло у нас?

›

05
Hunting
Встречалось ли ещё?

Поиск IP даёт подсказку.
Hunting проверяет гипотезу в событиях.

Сначала вопрос. Потом источник.

IP	Что сообщали об активности?	**AbuseIPDB**
SHA-256	Что известно об этих байтах?	**VirusTotal · файл**
Домен / URL	Какие сведения и связи есть?	**VirusTotal**
Сеанс	Кто и что сделал?	**Внутренние журналы**

Домен не заменяет полный URL. Имя файла не заменяет хеш.

AbuseIPDB · CHECK / VirusTotal · File object

AbuseIPDB: читаем историю

ПЕРИОД

Какое окно проверяем?

ДАТЫ

Когда сообщали?

КАТЕГОРИИ

Что наблюдали?

РЕПОРТЁРЫ

Кто и сколько раз?

≠

Оценка сервиса не равна вероятности нашего инцидента

Комментарии помогают понять содержание жалобы.

Количество сообщений ≠ количество атак. Нет жалоб ≠ безопасно.

AbuseIPDB · CHECK / AbuseIPDB · FAQ

VirusTotal: читаем весь отчёт

IP | ДОМЕН | URL | ФАЙЛ

Доля детектов ≠ вероятность атаки

Читать дальше:

дату · тип · поведение · связи

`malicious`
Считают вредоносным

`undetected`
Нет детекта / мнения

`harmless`
Считают невредоносным

`timeout / failure`
Результат не получен

Легитимная программа ≠ разрешённая сессия.

VirusTotal · Analysis object / VirusTotal · IP object

Что раскрывает внешний запрос?

ОТЧЁТ ПО ХЕШУ

Запрос известного отпечатка

UPLOAD

Содержимое файла

REANALYZE

Новый анализ объекта

VT предупреждает об анализе и включении запрошенных и переданных IoC в набор данных сообщества.

Приватные ссылки, токены и документы — в разрешённом контуре.

VirusTotal · Searching / VirusTotal · Upload / disclosure

Одна пара — два вопроса

SYGNIA · ИСТОРИЧЕСКИЙ ОБЪЕКТ · 2022

`maaays[.]xyz` ↔ `192[.]236[.]194[.]2`

Роль в таблице: Exfiltration Server — сервер для выноса данных.

ABUSEIPDB

Что сообщали об IP — и когда?

VIRUSTOTAL

Что известно о домене и датах связей?

Текущих оценок нет. К учебному компьютеру эта пара не привязана.

Sygnia · Luna Moth · 2022

Luna Moth: цепочка обмана

ЦЕПОЧКА ПО SYGNIA · 2022



Счёт	Звонок	Поддержка	Управление	Вынос данных
PDF о подписке	Жертва звонит сама	Zoho Assist	Atera	Rclone

Знакомый инструмент. Посторонний оператор.

Кампания Unit 42: хищение и вымогательство без шифрования.

Sygnia · Luna Moth · 2022 / Unit 42 · Callback Phishing · 2022

У связи есть время и основание

Источник

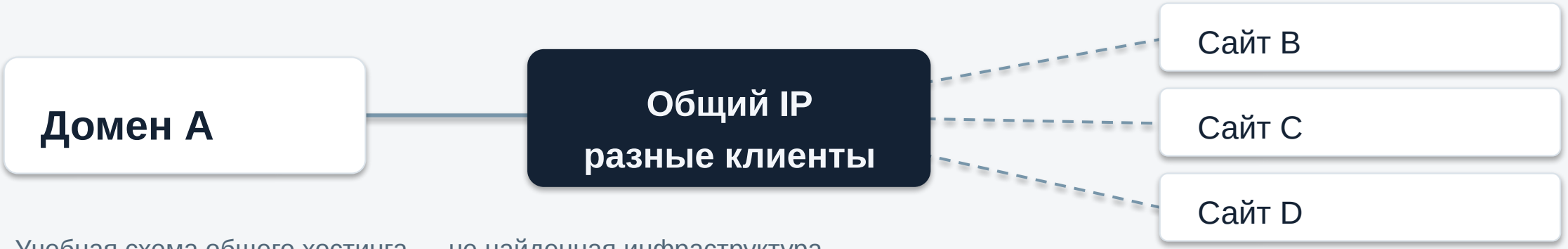
Откуда связь?

Время

Когда наблюдали?

Характер

Что связывает объекты?



Учебная схема общего хостинга — не найденная инфраструктура.

Кто разрешил доступ — и что сделал оператор?

Sygnia · Luna Moth · 2022 / VirusTotal · Domain object

Что произошло у нас?

Почта и сотрудник	Когда и откуда начался контакт?
Устройство и процесс	Что запустили?
Сессия поддержки	Кто подключался? Было ли разрешение?
Сеть и файлы	Какие обращения и передача видны?

Сопоставить: устройство · время · пользователь · процесс / сеанс

DNS-запрос ≠ соединение. Соединение ≠ кража.

Вывод, который можно проверить

УЧЕБНЫЙ ПРИМЕР · ПРОВЕРКА НЕ ВЫПОЛНЕНА

Факт	Сотрудник сообщил о запуске поддержки.
Контекст	Публичный кейс описывает похожую цепочку.
Гипотеза	Доступ мог быть несанкционированным.
Пробел	Согласование и действия не проверены.
Шаг	Проверить заявку, запуск, сеанс и сеть.

Сохраняем источник, дату и пределы вывода.

Hunting начинается с гипотезы

14 ДНЕЙ — УСЛОВИЕ УПРАЖНЕНИЯ

Возможное неразрешённое использование:

Удалённая поддержка → передача файлов

НАЙТИ

Запуски и сеансы

ПРОВЕРИТЬ

Последующие действия

СВЕРИТЬ

Заявки и операторов

До поиска: охват устройств, срок хранения и время событий.

Один объект.
Один вопрос.
Следующий шаг.

Проверить разрешённость сеанса
и действия оператора.

Спасибо! Вопросы?

- Объект
- Вопрос
- Источник
- Проверка
- **Действие**

Источники, на которые можно опереться

КЕЙС

Sygnia · Luna Moth, 2022

Unit 42 · Callback Phishing, 2022

РЕПУТАЦИЯ IP

AbuseIPDB · CHECK

AbuseIPDB · FAQ

ОТЧЁТЫ И ДАННЫЕ

VT · Analysis object

VT · Searching

VT · Upload / disclosure

Проверено 14 октября 2026 года.

Полные ссылки и основания — в заметках слайдов.

Сохранить себе: проверка объекта

1. Зафиксировать событие и время
2. Выбрать объект и вопрос
3. Проверить допустимость внешнего запроса
4. Прочитать содержание, источник и даты
5. Сопоставить с внутренними данными
6. Записать вывод, пробелы и действие

Событие → свидетельство → проверка → вывод → действие